

تقرير المشروع العملي الثاني

مراقبة وتدقيق قاعدة البيانات — Database Auditing & Monitoring

المقرر	أمن قواعد البيانات — Database Security
الطالب	خضر محمد خضر خضير
الرقم الجامعي	120191118
مدرس المقرر	م. أحمد شعث
التاريخ	19 أغسطس 2026

1. بيئة العمل

البند	القيمة
نظام إدارة قاعدة البيانات	Oracle Database 11g Express Edition 11.2.0.2.0
اسم القاعدة	XE
المخطط قيد المراقبة	KHADER
مخطط سجل التدقيق المخصص	SECAUD

تقسيم البيانات حسب الحساسية (وهو أساس المتطلبين الثاني والثالث):

الجدول	مستوى الحساسية	آلية المراقبة المطبقة
KHADER.EMPLOYEES	أقل حساسية	تدقيق قياسي (Standard Auditing)
KHADER.SALARIES	الأكثر حساسية	آليتان: تدقيق قياسي + مُشغّل (Trigger)

2. المتطلب الأول: تفعيل التدقيق القياسي مع حفظ جملة SQL

AUDIT_TRAIL متغير ساكن (Static)، أي لا يمكن تغييره أثناء التشغيل، بل يحتاج SCOPE = SPFILE ثم إعادة تشغيل القاعدة.

```
ALTER SYSTEM SET audit_trail = 'db_extended' SCOPE = SPFILE;
```

System altered.

ملاحظة مهمة على الإصدار 11g: الصيغة 'DB,EXTENDED' الواردة في ملفات المقرر تُنتج على هذا الإصدار الخطأ:

```
ORA-00096: invalid value DB,EXTENDED for parameter audit_trail, must be from among  
extended, xml, db_extended, false, true, none, os, db
```

والقيمة الصحيحة هنا هي db_extended .

معنى القيمة: - db → تُكتب سجلات التدقيق داخل القاعدة في الجدول SYS.AUD\$. - _extended → تُحفظ إضافةً إلى ذلك نصّ جملة SQL (SQLTEXT) والمتغيّرات المرتبطة (SQLBIND). بدونها يبقى العمود SQL_TEXT فارغاً (NULL).

بعد إعادة التشغيل:

```
SHOW PARAMETER audit_trail
```

NAME	TYPE	VALUE
audit_trail	string	DB_EXTENDED

```
[khader@dbsec ~]$ docker exec -it oracle-11g bash -lc 'sqlplus "sys/oracle@localhost:1521/XE as sysdba"'
SQL*Plus: Release 11.2.0.2.0 Production on Wed Aug 19 18:56:40 2026
Copyright (c) 1982, 2011, Oracle. All rights reserved.

Connected to:
Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production

SQL> show parameter audit_trail

NAME                                TYPE                                VALUE
-----                                -                                -
audit_trail                          string                              DB_EXTENDED
SQL> show parameter audit_sys_operat
```

لقطة شاشة 1

[لقطة شاشة 1] — تنفيذ ALTER SYSTEM ثم إعادة التشغيل وظهور القيمة DB_EXTENDED.

3. المتطلب الثاني: مراقبة البيانات الأقل حساسية

باستخدام التدقيق القياسي على مستوى الكائن، وبأسلوب ملف المقرر Oracle_Audit_Commands.txt :

```
AUDIT SELECT, INSERT, UPDATE, DELETE ON khader.employees BY ACCESS;
```

```
Audit succeeded.
```

كما أُضيفت مراقبة على مستوى الجلسات والصلاحيات:

```
AUDIT SESSION WHENEVER NOT SUCCESSFUL;  
AUDIT SYSTEM GRANT BY ACCESS;
```

تصحيح لصيغة واردة في ملف المقرر: الجملة: `AUDIT GRANT, REVOKE BY ACCESS;` غير صالحة على الإصدار 11g وتُنتج:

```
ORA-00956: missing or invalid auditing option
```

والصيغة الصحيحة لتدقيق منح وسحب الصلاحيات والأدوار هي `AUDIT SYSTEM GRANT BY ACCESS;`

الفرق بين `BY ACCESS` و `BY SESSION` : - `BY ACCESS` سجل تدقيق لكل تنفيذ للجملة. أدق لكنه أكبر حجماً. - `BY SESSION` سجل واحد مُجمّع لكل جلسة. أخفّ لكنه يُخفي عدد مرات الوصول.

اختير `BY ACCESS` لأن الهدف هو التتبع الدقيق.

```
Copyright (c) 1982, 2011, Oracle. All rights reserved.  
  
Connected to:  
Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production  
  
SQL> show parameter audit_trail  


| NAME        | TYPE   | VALUE       |
|-------------|--------|-------------|
| audit_trail | string | DB_EXTENDED |

  
SQL> show parameter audit_sys_operations  


| NAME                 | TYPE    | VALUE |
|----------------------|---------|-------|
| audit_sys_operations | boolean | TRUE  |

  
SQL> show parameter audit_file_dest  


| NAME            | TYPE   | VALUE                          |
|-----------------|--------|--------------------------------|
| audit_file_dest | string | /u01/app/oracle/admin/XE/adump |

  
SQL> audit select, insert, update, delete on khader.employees by access;  
  
Audit succeeded.  
  
SQL> audit grant, revoke by access;  
audit grant, revoke by access  
*  
ERROR at line 1:  
ORA-00956: missing or invalid auditing option  
  
SQL> a
```

لقطة شاشة 2

[لقطة شاشة 2] — أوامر التدقيق وظهور. Audit succeeded.

4. المتطلب الثالث والرابع: أليتان مختلفتان للبيانات الأكثر حساسية

4.1 الآلية الأولى — التدقيق القياسي على الكائن

```
AUDIT SELECT, INSERT, UPDATE, DELETE ON khader.salaries BY ACCESS;
```

Audit succeeded.

الميزة	القيد
لا تحتاج أي كود أو صيانة	تسجل الجملة لا القيم
تلتقط SELECT أيضاً	لا تظهر ما تغير فعلياً في الصف

4.2 الآلية الثانية – مُشغِّل (Trigger) يلتقط القيم القديمة والجديدة

هذه الآلية مأخوذة من ملف المقرر Old New Value Auditing.txt ومطورة لتشمل الثلاث عمليات. أنشئ مخطط مستقل SECAUD ليحتفظ بالسجلات بعيداً عن مالك البيانات:

```
CREATE USER secaud IDENTIFIED BY "Secaud#2026"
  DEFAULT TABLESPACE users QUOTA UNLIMITED ON users;

CREATE TABLE secaud.salary_audit_log (
  audit_id      NUMBER,
  action        VARCHAR2(10),
  action_user   VARCHAR2(30),
  action_time   TIMESTAMP,
  emp_id        NUMBER(6),
  old_salary    NUMBER(10,2),
  new_salary    NUMBER(10,2)
);

CREATE SEQUENCE secaud.seq_salary_audit START WITH 1 INCREMENT BY 1 NOCACHE;

GRANT INSERT ON secaud.salary_audit_log TO khader;
GRANT SELECT ON secaud.seq_salary_audit TO khader;
```

ملاحظتان على الإصدار 11g: لا يوجد GENERATED AS IDENTITY (أضيف في 12c)، لذلك استخدم SEQUENCE . 2 . يجب منح صلاحية INSERT قبل إنشاء المُشغِّل، وإلا فشل في الترجمة بالخطأ ORA-00942 .

```
CREATE OR REPLACE TRIGGER khader.trg_salaries_audit
AFTER INSERT OR UPDATE OR DELETE ON khader.salaries
FOR EACH ROW
DECLARE
  v_action VARCHAR2(10);
BEGIN
  IF inserting THEN
    v_action := 'INSERT';
  ELSIF updating THEN
    v_action := 'UPDATE';
  ELSE
    v_action := 'DELETE';
  END IF;

  INSERT INTO secaud.salary_audit_log
    (audit_id, action, action_user, action_time, emp_id, old_salary, new_salary)
  VALUES (secaud.seq_salary_audit.NEXTVAL,
    v_action, USER, SYSTIMESTAMP,
    NVL(:new.emp_id, :old.emp_id),
    :old.base_salary,
    :new.base_salary);
END;
```

Trigger created.

نقطة برمجية مهمة للمناقشة: الدوال INSERTING و UPDATING و DELETING هي دوال PL/SQL ولا يجوز استخدامها داخل جملة SQL. وضعها في تعبير CASE ضمن VALUES يُنتج:

PL/SQL: ORA-00920: invalid relational operator

لذلك يُحسم نوع العملية في PL/SQL أولاً ثم يُمرّر المتغير إلى جملة INSERT .

4.3 لماذا الآليتان مُكمّلتان وليستا مكرّرتين؟

المعيار	التدقيق القياسي	المُشغّل
يلتقط SELECT	نعم	لا (المُشغّلات تعمل على DML فقط)
يُظهر القيم قبل/بعد	لا	نعم
يحتاج كودًا وصيانة	لا	نعم
مكان التخزين	SYS.AUD\$	جدول مخصّص في مخطط منفصل

الخلاصة: التدقيق القياسي يجب عن سؤال «من نفّذ ماذا ومتى»، والمُشغّل يجب عن سؤال «ما القيمة التي تغيّرت وإلى ماذا». ولا تُغني إحداهما عن الأخرى.

4.4 ملاحظة على التدقيق الدقيق (Fine-Grained Auditing)

يغطّي المقرر أيضًا DBMS_FGA (ملف FGA.txt). غير أن FGA خاصة حصريّة بنسخة Enterprise Edition وغير متاحة في Express Edition، وأي محاولة لإنشاء سياسة تُنتج:

ORA-00439: feature not enabled: Fine-grained Auditing

وقد تحقّقنا من ذلك عملياً. ونصّر المشروع يشترط تنفيذ آلية المُشغّل «إن كانت مدعومة في بيئة العمل»، لذلك اعتُمدت الآليتان المذكورتان أعلاه، وهما نفسهما الآليتان الواردتان في ملف المقرر Old New Value Auditing.txt .

```

SQL> create user secaud identified by "Secaud#2026" default tablespace users quota unlimited on users;

User created.

SQL> create table secaud.salary_audit_log (audit_id number, action varchar2(10), action_user varchar2(30), action_time timestamp, emp_id number(6), old_salary number(10,2), new_salary number(10,2));

Table created.

SQL> create sequence secaud.seq_salary_audit start with 1 increment by 1 nocache;

Sequence created.

SQL> desc secaud.salary_audit_log
Name                                Null?    Type
-----
AUDIT_ID                            NUMBER
ACTION                             VARCHAR2(10)
ACTION_USER                         VARCHAR2(30)
ACTION_TIME                         TIMESTAMP(6)
EMP_ID                              NUMBER(6)
OLD_SALARY                          NUMBER(10,2)
NEW_SALARY                          NUMBER(10,2)

SQL> grant insert on secaud.salary_audit_log to khader;

Grant succeeded.

SQL> grant select on secaud.seq_salary_audit to khader;

Grant succeeded.

SQL> create or replace trigger khader.trg_salaries_audit after insert or update or delete on khader.salaries for each row declare v_action varchar2(10); begin if inserting then v

```

لقطة شاشة 3

[لقطة شاشة 3] — إنشاء جدول التدقيق والمُسجَّل وظهور Trigger created.

5. المتطلب الخامس: حماية سجلات التدقيق من مسؤول قاعدة البيانات

طبقت الحماية على ثلاث طبقات:

الطبقة الأولى — تدقيق سجل التدقيق نفسه

```

AUDIT ALL ON sys.aud$ BY ACCESS;
AUDIT DELETE ANY TABLE BY ACCESS;

```

Audit succeeded.

أي محاولة للاطلاع على SYS.AUD\$ أو حذف محتواه تُخلف سجل تدقيق خاص بها.

الطبقة الثانية — نقل تدقيق العمليات المميّزة خارج قاعدة البيانات

```

ALTER SYSTEM SET audit_sys_operations = TRUE SCOPE = SPFILE;
SHOW PARAMETER audit_file_dest

```

NAME	TYPE	VALUE
audit_file_dest	string	/u01/app/oracle/admin/XE/adump

عمليات SYSDBA تُكتب في ملفات على نظام التشغيل خارج القاعدة، فلا يستطيع مسؤول قاعدة البيانات حذفها بأوامر SQL — بل يحتاج صلاحية على نظام التشغيل، وهي يجب أن تكون بيد شخص آخر (مبدأ فصل المهام / Separation of Duties).

الطبقة الثالثة — جعل جدول التدقيق للإضافة فقط (Append-Only)

```
CREATE OR REPLACE TRIGGER secaud.trg_protect_salary_log
BEFORE UPDATE OR DELETE ON secaud.salary_audit_log
BEGIN
    raise_application_error(-20999,
        'Audit records are append-only and cannot be modified or deleted.');
```

Trigger created.

الحدّ الحقيقي لهذه الحماية — نقطة للمناقشة

مسؤول قاعدة البيانات يملك ALTER ANY TRIGGER و DROP ANY TABLE، فيستطيع نظرياً تعطيل الطبقة الثالثة. الفصل الكامل للمهام يتطلب Oracle Database Vault أو Audit Vault، وكلاهما غير متوفر في Express Edition — وقد تحقّقنا من ذلك:

```
SELECT parameter, value FROM v$option WHERE parameter = 'Oracle Database Vault';
```

PARAMETER	VALUE
Oracle Database Vault	FALSE

لذلك تبقى الطبقة الثانية (سجلّ نظام التشغيل) هي أقوى ضابط متاح فعلياً في هذه البيئة.

```
Sequence created.

SQL> desc secaud.salary_audit_log
Name                               Null?    Type
-----
AUDIT_ID                           NUMBER
ACTION                             VARCHAR2(10)
ACTION_USER                         VARCHAR2(30)
ACTION_TIME                         TIMESTAMP(6)
EMP_ID                             NUMBER(6)
OLD_SALARY                         NUMBER(10,2)
NEW_SALARY                         NUMBER(10,2)

SQL> grant insert on secaud.salary_audit_log to khader;

Grant succeeded.

SQL> grant select on secaud.seq_salary_audit to khader;

Grant succeeded.

SQL> create or replace trigger khader.trg_salaries_audit after insert or update or delete on khader.salaries for each row declare v_action varchar2(10); begin if inserting then v_action := 'INSERT'; elsif updating then v_action := 'UPDATE'; else v_action := 'DELETE'; end if; insert into secaud.salary_audit_log values (secaud.seq_salary_audit.nextval, v_action, user, systimestamp, nvl(new.emp_id, :old.emp_id), :old.base_salary, :new.base_salary); end;
2 /

Trigger created.

SQL> audit all on sys.aud$ by access;

Audit succeeded.

SQL> create or replace trigger secaud.trg_protect_salary_log before up
```

6. المتطلب السادس: تحليل نتائج التدقيق

6.1 توليد نشاط حقيقي

```
CONNECT khader_pwd/"Khader#120191118"@localhost:1521/XE

SELECT emp_id, full_name FROM khader.employees WHERE emp_id = 1001;
UPDATE khader.employees SET dept = 'Security' WHERE emp_id = 1001;
COMMIT;
SELECT * FROM khader.salaries;      -- محاولة غير مصرّح بها

CONNECT sys/oracle@localhost:1521/XE AS SYSDBA

UPDATE khader.salaries SET base_salary = 9999.99 WHERE emp_id = 1001;
DELETE FROM khader.salaries WHERE emp_id = 1003;
COMMIT;
```

6.2 نتيجة الآلية الأولى — التدقيق القياسي

```
SELECT username, action_name, obj_name, sql_text, timestamp
FROM dba_audit_trail
WHERE obj_name IN ('EMPLOYEES', 'SALARIES')
ORDER BY timestamp;
```

USERNAME	ACTION_NAME	OBJ_NAME	SQL_TEXT	TIMESTAMP
KHADER_PWD	SELECT	EMPLOYEES	select emp_id, full_name, dept from khader.employees	19-AUG-26
KHADER_PWD	INSERT	EMPLOYEES	insert into khader.employees values (1004, 'Test User'	19-AUG-26
KHADER_PWD	SELECT	SALARIES	select * from khader.salaries	19-AUG-26
KHADER_PWD	SELECT	EMPLOYEES	select emp_id, full_name from khader.employees where	19-AUG-26
KHADER_PWD	UPDATE	EMPLOYEES	update khader.employees set dept = 'Security' where	19-AUG-26
KHADER_PWD	SELECT	SALARIES	select * from khader.salaries	19-AUG-26

6 rows selected.

قراءة النتيجة: - ظهر عمود SQL_TEXT كاملاً — وهذا الدليل المباشر على أن db_extended تعمل. - سجّلت المحاولات الفاشلة أيضاً على SALARIES، وهي أهم من الناجحة أمنياً.

استعلام المحاولات غير المصرّح بها:

```
SELECT username, action_name, returncode, timestamp
FROM dba_audit_trail
WHERE returncode <> 0
ORDER BY timestamp;
```

USERNAME	ACTION_NAME	RETURNCODE	TIMESTAMP
KHADER_PWD	SELECT	2004	19-AUG-26
KHADER_PWD	SELECT	2004	19-AUG-26

RETURNCODE = 2004 يعني رفض الوصول لعدم وجود صلاحية.

6.3 نتيجة الآلية الثانية — المُشغّل


```
SELECT audit_id, action, action_user, emp_id, old_salary, new_salary, action_time
FROM secaud.salary_audit_log
ORDER BY audit_id;
```

AUDIT_ID	ACTION	ACTION_USER	EMP_ID	OLD_SALARY	NEW_SALARY	ACTION_TIME
1	UPDATE	SYS	1001	4500	9999.99	19-AUG-26 05.54.33.478990 PM
2	DELETE	SYS	1003	3900		19-AUG-26 05.54.33.504629 PM

قراءة النتيجة — وهنا يظهر الفرق الجوهرى بين الآليتين: - السطر 1: تعديل الراتب من **4500** إلى **9999.99** — القيمة القديمة والجديدة معاً. - السطر 2: حذف صف راتبه **3900** القيمة الجديدة فارغة لأن الصف حُذف. - التدقيق القياسي كان سيعرض جملة UPDATE فقط دون أي من هذه الأرقام.

6.4 إثبات فاعلية الحماية

```
DELETE FROM secaud.salary_audit_log;
```

```
delete from secaud.salary_audit_log
*
ERROR at line 1:
ORA-20999: Audit records are append-only and cannot be modified or deleted.
ORA-06512: at "SECAUD.TRG_PROTECT_SALARY_LOG", line 2
ORA-04088: error during execution of trigger 'SECAUD.TRG_PROTECT_SALARY_LOG'
```

```
UPDATE secaud.salary_audit_log SET new_salary = 0;
```

```
ORA-20999: Audit records are append-only and cannot be modified or deleted.
```

رُفضت العمليتان رغم أن الجلسة متصلة بصلاحيّة SYSDBA — وهو أعلى مستوى صلاحية في القاعدة.

```

-----
KHADER_PWD  UPDATE      EMPLOYEES
update khader.employees set dept = 'Security' wher
e emp_id = 1001

KHADER_PWD  SELECT      SALARIES
select * from khader.salaries

KHADER_PWD  SELECT      EMPLOYEES

USERNAME    ACTION_NAM OBJ_NAME
-----
SQL_TEXT

-----
select emp_id, full_name from khader.employees whe
re emp_id = 1001

KHADER_PWD  UPDATE      EMPLOYEES
update khader.employees set dept = 'Security' wher
e emp_id = 1001

KHADER_PWD  SELECT      SALARIES
select * from khader.salaries

USERNAME    ACTION_NAM OBJ_NAME
-----
SQL_TEXT

-----

15 rows selected.

SQL> s

```

لقطة شاشة 5

[لقطة شاشة 5] — نتائج DBA_AUDIT_TRAIL .

```

-----
SQL_TEXT
-----

15 rows selected.

SQL> select username, action_name, returncode from dba_audit_trail where returncode <> 0 order by timestamp;

USERNAME    ACTION_NAM RETURNCODE
-----
KHADER_PWD  SELECT      2004
KHADER_PWD  SELECT      2004
KHADER_PWD  SELECT      2004
KHADER_PWD  LOGON       1017
KHADER_PWD  LOGON       1017
KHADER_PWD  LOGON       1017
KHADER_PWD  SELECT      2004
KHADER_PWD  SELECT      2004

8 rows selected.

SQL> select audit_id, action, action_user, emp_id, old_salary, new_salary from secaud.salary_audit_log order by audi
t_id;

AUDIT_ID ACTION    ACTION_USER EMP_ID OLD_SALARY
-----
NEW_SALARY
-----
1 UPDATE    SYS          1001 4500
9999.99

SQL> delete from

```

[لقطة شاشة 6] — نتائج جدول المُشغِّل مع القيم القديمة والجديدة.

```
KHADER_PWD  SELECT          2004

8 rows selected.

SQL> select audit_id, action, action_user, emp_id, old_salary, new_salary from secaud.salary_audit_log order by audit_id;

  AUDIT_ID ACTION      ACTION_USER      EMP_ID OLD_SALARY
-----
NEW_SALARY
-----
          1 UPDATE      SYS              1001      4500
9999.99

SQL> delete from secaud.salary_audit_log;
delete from secaud.salary_audit_log
      *
ERROR at line 1:
ORA-20999: Audit records are append-only and cannot be modified or deleted.
ORA-06512: at "SECAUD.TRG_PROTECT_SALARY_LOG", line 1
ORA-04088: error during execution of trigger 'SECAUD.TRG_PROTECT_SALARY_LOG'

SQL> update secaud.salary_audit_log set new_salary = 0;
update secaud.salary_audit_log set new_salary = 0
      *
ERROR at line 1:
ORA-20999: Audit records are append-only and cannot be modified or deleted.
ORA-06512: at "SECAUD.TRG_PROTECT_SALARY_LOG", line 1
ORA-04088: error during execution of trigger 'SECAUD.TRG_PROTECT_SALARY_LOG'

SQL> s
```

[لقطة شاشة 7] — فشل الحذف بالخطأ ORA-20999 .

7. الخلاصة

المتطلب	الحالة	الدليل
تدقيق قياسي داخل القاعدة مع حفظ جملة SQL		AUDIT_TRAIL = DB_EXTENDED وعمود SQL_TEXT ممثلي
مراقبة البيانات الأقل حساسية		AUDIT ... ON khader.employees BY ACCESS
آليتان مختلفتان للبيانات الأكثر حساسية		تدقيق قياسي + مُشغِّل يلتقط القيم
تنفيذ مُشغِّل التدقيق عملياً		TRG_SALARIES_AUDIT — سجِّل تعديلاً وحذفاً
حماية سجلات التدقيق من DBA		ثلاث طبقات + ORA-20999 رغم SYSDBA
تحليل السجلات وشرح كل آلية		القسم 6

أهم النقاط للمناقشة الشفوية:

1. `AUDIT_TRAIL` متغير ساكن $\Rightarrow$ `SCOPE=SPFILE` + إعادة تشغيل. وعلى 11g قيمته `db_extended`.
2. الفرق بين الآليتين: التدقيق القياسي يلتقط **الجملة** ويشمل `SELECT`؛ والمُشغّل يلتقط **القيم** لكنه لا يرى `SELECT` إطلاقاً.
3. `BY ACCESS` مقابل `BY SESSION`.
4. حماية السجلات تعتمد جوهرياً على إخراجها من القاعدة إلى نظام التشغيل، لأن الـ DBA يملك داخل القاعدة صلاحيات تُمكنه من تعطيل أي حماية داخلية.
5. FGA غير متاح في (Express Edition (ORA-00439، وهو قيد بيئة لا قيد تصميم.